

OWASP ZAP

DAST and Web application security analysis in authorized environments.

What OWASP ZAP is

OWASP ZAP (Zed Attack Proxy) is an open-source web application security testing tool maintained within the OWASP ecosystem. It can work as an intercepting proxy and perform passive and active analysis, helping QA include DAST-oriented checks in authorized test environments.

Passive Scan

Passive Scan analyzes traffic that passes through ZAP without actively attacking the target. It can highlight headers, cookie attributes, mixed content and other observable security signals, making it a useful starting point because it has lower risk of changing application state.

Active Scan

Active Scan sends requests designed to probe potential vulnerabilities. It is intrusive and can change data or affect availability, so use it only against explicitly authorized targets and controlled environments, with scope, credentials and stop conditions agreed in advance.

Quick Start and proxy

Use Quick Start for guided exploration or configure the browser/application to proxy traffic through ZAP. Confirm the target scope, HTTPS certificate handling and authentication before scanning. Start by navigating the application and reviewing passive findings before enabling more invasive actions.

QA and DAST in CI

ZAP can support automated DAST checks in CI/CD, but the pipeline should define the target, authentication, baseline policy, accepted risk and failure criteria. Treat findings as inputs for triage rather than assuming every alert is a confirmed vulnerability; correlate with evidence and security review.

Attention point

Security testing must be authorized. Never run active scans against production, third-party systems or environments outside the agreed scope. Protect credentials and captured traffic, avoid exposing sensitive data in reports and involve security specialists for high-impact findings.